Tutorials Exercises W3Schools app iOS & Android NEW Sign In
. CSS JAVASCRIPT SQL PYTHON JAVA PHP C C++ C# AWS

MySQL - Prepared Statements

‹ Previous Next ›

MySQL - Prepared Statements

SHARE

Prepared statements is used to protect a web site from SQL injections.

Prepared statements seperates the query structure (the SQL) from the actual data (user input).

Prepared statements basically work like this:

1. **Prepare:** An SQL query template with placeholders is sent to the server. The data values are not sent. Example: INSERT INTO MyGuests VALUES(?, ?, ?). Then, the server parses, compiles, and optimizes the SQL query template, without executing it
2. **Execute:** At a later time, the application binds the values to the parameters, and the database executes the query. The application may execute the query as many times as it wants with different values

Prepared statements have four main advantages:

- **Reduced parsing time** - as the preparation on the query is done only once (although the statement is executed multiple times)

Tutorials Exercises W3Schools app iOS & Android NEW Sign In
CSS JAVASCRIPT SQL PYTHON JAVA PHP C C++ C# AWS

escaped. If the original statement template is not derived from external input, SQL injection cannot occur

- **Cleaner code** - by seperating data from SQL commands

Prepared Statements in MySQL

The following example is taken from PHP MySQL Prepared Statements, and uses prepared statements in MySQL:

Example - MySQL with Prepared Statements

Get your own SQL Server

```
<?php
$servername = "localhost";
$username = "username";
$password = "password";
$dbname = "myDB";

// Create connection
$conn = new mysqli($servername, $username, $password, $dbname);

// Check connection
if ($conn->connect_error) {
  die("Connection failed: " . $conn->connect_error);
}

// SQL query template
$sql = "INSERT INTO MyGuests (firstname, lastname, email) VALUES (?, ?, ?)";

// Prepare the SQL query template
if($stmt = $conn->prepare($sql)) {
  // Bind parameters
  $stmt->bind_param("sss", $firstname, $lastname, $email);

  // Set parameters and execute
  $firstname = "John";
```

W3Schools app iOS & Android NEW Sign In

. CSS JAVASCRIPT SQL PYTHON JAVA PHP C C++ C# AWS

```
  $firstname = "Mary";
  $lastname = "Moe";
  $email = "mary@example.com";
  $stmt->execute();

  $firstname = "Julie";
  $lastname = "Dooley";
  $email = "julie@example.com";
  $stmt->execute();
  echo "New records created successfully";
} else {
  echo "Error: " . $sql . "<br>" . $conn->error;
}

$stmt->close();
$conn->close();
?>
```

Code Explanation

In the SQL, the question marks (?) are placeholders for *firstname*, *lastname*, and *email* values:

```
"INSERT INTO MyGuests (firstname, lastname, email) VALUES (?, ?, ?)"
```

Now, look at the `bind_param()` function. This function bind variables to the placeholders in the SQL query. The placeholders (?) will be replaced by the actual values held in the variables at the time of execution. The "sss" argument lists the **type** of data each parameter is. The **s** character tells mysql that the parameter is a string. We must define one of these for EACH parameter. By telling mysql what type of data to expect, we minimize the risk of SQL injections:

Tutorials Exercises W3Schools app iOS & Android NEW Sign In
. CSS JAVASCRIPT SQL PYTHON JAVA PHP C C++ C# AWS

The type argument can be one of four types:

- **i** - integer (whole number)
- **d** - double (floating point number)
- **s** - string (text)
- **b** - binary (image, PDF, etc.)

Note: If we want to insert data from external sources (like user input), it is very important that the data is sanitized and validated.

REMOVE ADS

‹ Previous Next ›

Sign in to track progress


schools
Your next career move.
Get every certification. One payment.
CERTIFICATE OF COMPLETION
Your Name
Certified Developer
$499
Pay once. Learn for life.
Invest in your future

REMOVE ADS

Tutorials Exercises W3Schools app iOS & Android NEW Sign In

CSS JAVASCRIPT SQL PYTHON JAVA PHP C C++ C# AWS

FREE ACCOUNT

Track your progress

XP earned 0

Day streak 0

Spaces 0

League —

Sign in to track progress

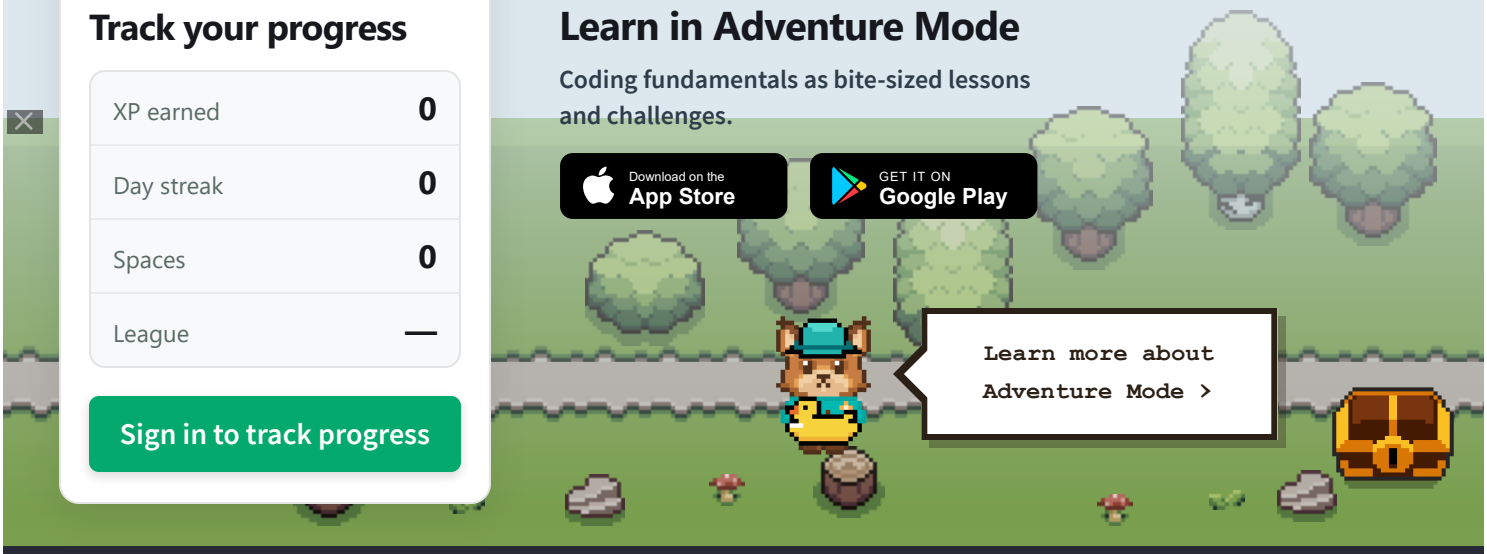
NEW

Learn in Adventure Mode

Coding fundamentals as bite-sized lessons and challenges.

Download on the App Store GET IT ON Google Play

Learn more about Adventure Mode >



PLUS SPACES

GET CERTIFIED FOR TEACHERS

PRACTICE CONTACT US

Top Tutorials

HTML Tutorial
CSS Tutorial
JavaScript Tutorial
How To Tutorial
SQL Tutorial

Tutorials Exercises W3Schools app iOS & Android NEW Sign In

. CSS JAVASCRIPT SQL PYTHON JAVA PHP C C++ C# AWS

jQuery Tutorial

Top References

HTML Reference
CSS Reference
JavaScript Reference
SQL Reference
Python Reference
W3.CSS Reference
Bootstrap Reference
PHP Reference
HTML Colors
Java Reference
AngularJS Reference
jQuery Reference

Top Examples

HTML Examples
CSS Examples
JavaScript Examples
How To Examples
SQL Examples
Python Examples
W3.CSS Examples
Bootstrap Examples
PHP Examples
Java Examples
XML Examples
jQuery Examples

Get Certified

HTML Certificate
CSS Certificate
JavaScript Certificate
Front End Certificate
SQL Certificate
Python Certificate
PHP Certificate
jQuery Certificate
Java Certificate
C++ Certificate
C# Certificate
XML Certificate

FORUM ABOUT CAMPUS

W3Schools is optimized for learning and training. Examples might be simplified to improve reading and learning.
Tutorials, references, and examples are constantly reviewed to avoid errors, but we cannot warrant full correctness
of all content. While using W3Schools, you agree to have read and accepted our terms of use, cookies and privacy policy.

Copyright 1999-2026 by Refsnes Data. All Rights Reserved. W3Schools is Powered by W3.CSS.